

REMEDICATION ENABLEMENT FRAMEWORK

Retest Readiness and Evidence

Purpose

Define a platform-neutral reference process for helping clients prepare security findings for retest, understand what supporting evidence is useful, and preserve independent consultant validation as the only basis for a remediation outcome.

Author: Daniel Jones

Version: 1.0

Status: Portfolio-ready reference process specification

Design position: Platform-neutral, evidence supports validation, automation optional

Contents

1	Executive Summary
2	Purpose, Scope and Applicability
3	Working Definitions
4	Core Principle and Responsibility Boundary
5	Principles for Useful Retest Evidence
6	Common Evidence Categories
7	Evidence Guidance by Finding Type
8	Common Evidence Problems
9	Platform-Neutral Reference Workflow
10	Consultant Review and Retest Outcomes
11	Optional Automation and AI Assistance
12	Implementation Model
13	Risks and Controls
14	Validation Criteria
15	Conclusion
Appendix A	Example Retest Readiness Record

1. Executive Summary

A retest is intended to independently verify whether a previously identified security finding has been remediated, partially remediated, remains unresolved, or has changed in a way that affects the original conclusion. Clients may know that a change has been made but still be uncertain about what information is useful to provide before validation begins.

This framework provides a consistent and proportionate way to prepare for retesting. It helps a client or remediation owner describe what changed, identify the affected scope, note exceptions, and supply relevant supporting evidence where useful. The assessor can then use that context to prepare the validation activity without treating the submitted material as proof of remediation.

The framework is platform-neutral. It can be adapted to a penetration-testing workflow, vulnerability-management platform, ticketing system, client portal, manual process or other finding-management environment. It does not depend on a particular vendor or delivery platform.

Core principle

Evidence supports the retest; it does not replace the retest. A finding should only be treated as remediated or verified after the agreed validation activity has been completed and the assessor is satisfied with the result.

2. Purpose, Scope and Applicability

The framework is intended for retesting and remediation validation of findings produced through authorised security assessments and reviews. Its purpose is to improve preparation and reduce avoidable uncertainty while preserving the distinction between client-supplied evidence and independent technical validation.

It is deliberately lightweight. Supporting evidence should assist the process rather than become a new compliance burden or a mandatory documentary exercise where it adds little value.

2.1 In scope

- Helping a client or remediation owner identify when a finding is ready for validation.
- Capturing what changed, which systems, users or endpoints were addressed, and any known exceptions.
- Providing examples of useful supporting evidence by finding category.
- Allowing relevant evidence or notes to accompany a retest request where useful.
- Presenting the original finding, remediation claim and supporting context together for the assessor.
- Recording retest outcomes accurately, including partial or unable-to-validate states.

2.2 Out of scope

- Treating uploaded evidence as automatic proof that a finding is resolved.
- Marking findings remediated without independent validation.
- Requiring unnecessary evidence where the retest can be performed effectively without it.
- Changing the original severity or technical conclusion without the normal assessment process.
- Autonomous testing or changes to client systems.
- Providing guarantees that a configuration, control or environment is secure or compliant based solely on submitted evidence.

3. Working Definitions

Term	Working meaning
Remediation	A change intended to resolve or materially reduce the identified security weakness.
Supporting evidence	Information supplied by the client to show what change has been made or to help the assessor understand the current state before retesting.
Retest / remediation validation	Independent follow-up testing intended to determine whether the original finding remains present, has been remediated, or has changed in a way that affects the original conclusion.
Retest readiness	The point at which the client believes the relevant remediation work is sufficiently complete for validation to be worthwhile.
Verified / remediated	A status applied only after the agreed validation confirms that the original condition has been satisfactorily addressed within the validated scope.
Partial remediation	A situation in which some elements of the issue have been addressed but the original risk remains in part or the implemented change does not cover the full affected scope.
Unable to validate	A state in which meaningful verification cannot be completed because the service, access path, test conditions or required scope are unavailable.
Changed condition	A state in which the environment has changed enough that the original issue is no longer directly comparable and may require a new finding or assessment decision.

4. Core Principle and Responsibility Boundary

The framework should improve preparation without transferring responsibility for remediation implementation to the assessor or allowing client-supplied evidence to determine the outcome. Screenshots, change records and configuration exports may show that work has taken place, but they do not necessarily prove that the original weakness is no longer exploitable or that every affected element has been addressed.

Client / remediation owner	Security assessor / consultant
Implement remediation or mitigation.	Explain what evidence may be useful for preparation.
Confirm which systems, users, applications or endpoints were changed.	Review supplied evidence as context.
Supply relevant supporting evidence where available.	Independently validate the affected finding.
Explain known exceptions, exclusions or limitations.	Determine the retest outcome.
Request validation when the change is believed to be ready.	Record unresolved, partially remediated, verified or other applicable outcomes accurately.

Responsibility boundary

The client implements and describes the change. The assessor independently verifies the security result.

5. Principles for Useful Retest Evidence

Relevant

Evidence should relate directly to the finding being retested rather than provide generic assurance that a security change was made.

Current

Evidence should reflect the environment after remediation, not the configuration or state that existed before the change.

Scoped

Where multiple assets, users or applications were affected, the material should make clear which parts of the original scope have been addressed.

Understandable

The assessor should be able to determine what changed without relying on unexplained screenshots or ambiguous statements.

Proportionate

The client should not be asked for extensive evidence when the retest can be completed effectively without it. The aim is to reduce friction, not create a new compliance burden.

Non-determinative

Evidence can support preparation and focus validation, but it must not automatically mark a finding as resolved.

6. Common Evidence Categories

Evidence category	Typical examples	What it helps establish
Configuration evidence	Relevant policy, configuration export, selected setting or service configuration.	Shows the intended control or setting after remediation.
Version / patch evidence	Current software version, package version, build number or patch reference.	Shows that an outdated or unsupported component may have been upgraded.
Change-management evidence	Change ticket, implementation note or maintenance record.	Provides context on what was changed and when.
Access-control evidence	Role assignment, group membership, policy scope or permission view.	Shows that identified access or privilege changes may have been applied.
Network-control evidence	Firewall rule, ACL, listening-service output or network configuration.	Shows that exposure or reachability may have been restricted.
Application evidence	Updated response, code/configuration excerpt or relevant application setting.	Shows how an application-side weakness was addressed.
Client verification output	Current scan result, command output or system-generated report.	Shows the client-observed post-change state before independent validation.

7. Evidence Guidance by Finding Type

A practical framework should not prescribe one mandatory evidence set for every finding. Evidence guidance should be tailored to the finding category and remain optional or proportionate unless a specific validation process requires otherwise.

Finding type	Useful supporting evidence may include	Important caution
Legacy TLS / weak cipher configuration	Updated TLS configuration; current protocol or cipher output; affected endpoint confirmation.	A configuration screenshot alone does not prove that the live service presents the intended protocols externally.
Missing MFA / weak authentication control	Updated authentication or access policy; scope of affected users; details of exclusions.	Policy configuration must still be validated against the originally affected accounts or access path.
Unsupported / outdated software	Current software version; upgrade record; affected host or service confirmation.	A version change may not cover every affected asset or may introduce a different unsupported branch.
Firewall / exposed service	Updated firewall or ACL rule; listening-service evidence; network diagram or change reference where useful.	The retest should still verify reachability from the relevant test position.
HTTP security header issue	Updated HTTP response or configuration showing the header and value.	The assessor should validate the header on the relevant endpoints and response paths.
Excessive privilege / stale account	Updated role or group membership; account status; policy or access-review evidence.	The retest should confirm that the originally identified privilege path has actually been removed.
SQL injection / input handling	Relevant application change note; code/configuration excerpt where appropriate; test-environment result.	Client evidence must not substitute for independent testing of the affected parameter and application behaviour.
Cross-site scripting	Updated encoding or validation behaviour; application change note; framework/configuration evidence where relevant.	The assessor should retest the original injection and execution path rather than rely solely on screenshots.
Certificate / trust issue	Updated certificate details; trust-chain evidence; service endpoint confirmation.	The live service must still be checked to confirm that the expected certificate and chain are actually presented.

8. Common Evidence Problems

"This has been fixed."

Useful as a status update, but it does not explain what changed or whether every affected element was addressed.

Unlabelled screenshots

A screenshot may be useful, but without a hostname, account, policy, endpoint or other identifier it may be difficult to map back to the original finding.

Evidence from the wrong environment

A staging or test-environment change may not demonstrate that the production or originally affected environment has been addressed.

Partial-scope evidence

Evidence for one host, user or endpoint may not address a finding that affected several assets or accounts.

Pre-change evidence

Old scans or configuration exports do not establish the post-remediation state.

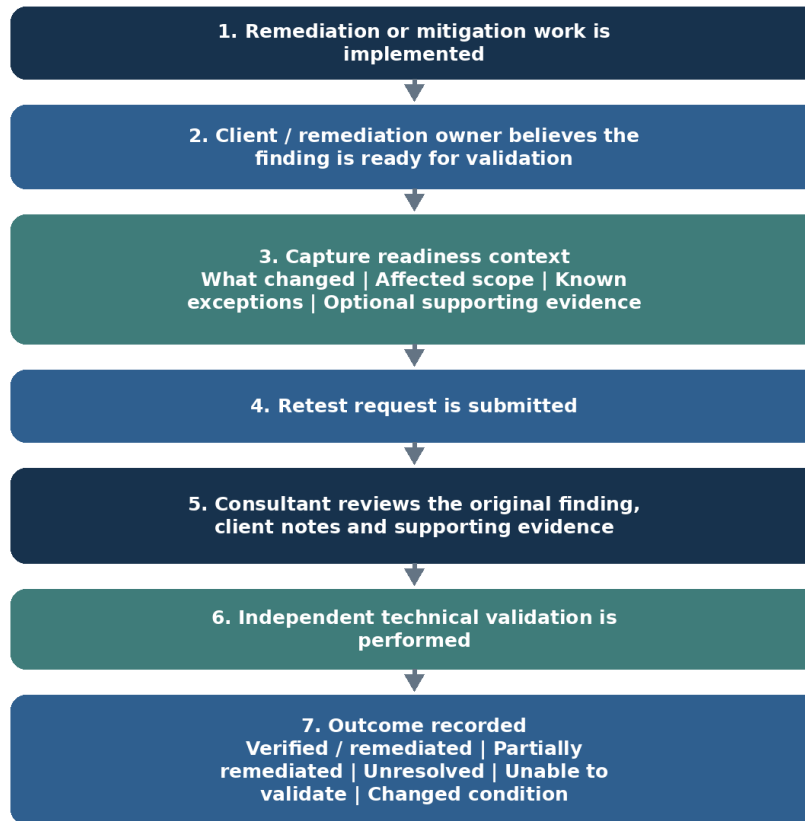
Evidence of intended change only

A change ticket or planned configuration can show intent, but not necessarily successful implementation.

9. Platform-Neutral Reference Workflow

The workflow below is a reference process rather than a prescribed interface. It can be implemented through a portal, ticketing system, vulnerability-management platform, email-assisted process, or other controlled finding-management mechanism.

Platform-Neutral Retest Readiness Reference Workflow



9.1 Reference process steps

1. The client or remediation owner implements the intended remediation or mitigation.
2. The client determines that the change is sufficiently complete for validation to be worthwhile.
3. The readiness record captures what changed, which parts of the original scope were addressed, any known exceptions and optional supporting evidence.
4. The retest request is submitted with the original finding remaining the source of truth.
5. The assessor reviews the original finding, remediation notes and supporting material to understand the claimed change.
6. The assessor independently performs the appropriate technical validation.
7. The outcome is recorded accurately as verified/remediated, partially remediated, unresolved, unable to validate, changed condition, or another state defined by the applicable reporting process.

9.2 Example client-facing guidance

Preparing this finding for retest

If remediation has been completed, you may provide supporting information to help the assessor understand what changed and where validation should be focused. Useful evidence depends on the finding and may include updated configuration, version information, policy settings, change references or current system output. Supporting evidence can help prepare the retest but does not replace independent verification.

10. Consultant Review and Retest Outcomes

The process should make retest preparation easier rather than create another document-heavy review stage. The ideal presentation places the original finding, client notes and supporting evidence together so the assessor can quickly understand the remediation claim and move to technical validation.

Consultant check	Question
Scope	Does the evidence appear to cover the originally affected systems, users, applications or endpoints?
Change understood	Is it clear what the client believes has changed?
Exceptions	Has the client identified any remaining exclusions or partial remediation?
Evidence relevance	Does the submitted material relate to the finding being retested?
Independent validation	What test is still required to determine the actual outcome?

10.1 Retest outcome states

Outcome	Meaning
Verified / remediated	The original condition is no longer present within the validated scope.
Partially remediated	Some affected systems, users or paths have been addressed but the original issue remains in part.
Unresolved	The original condition remains reproducible or the remediation did not address the cause.
Unable to validate	Meaningful verification cannot be completed because the service, access path, test conditions or required scope are unavailable.
Changed condition	The environment has changed enough that the original issue is no longer directly comparable and may require a new finding or assessment decision.

11. Optional Automation and AI Assistance

The framework must operate without AI. Automation or AI may be introduced later as a contextual assistance layer where it improves consistency, reduces repetitive administration or helps structure submitted information without making a security-status decision.

Automation / AI may assist with	Example use	Boundary
Tailor evidence guidance to the approved finding	For a TLS finding, suggest current protocol or cipher output and endpoint confirmation.	Must stay within the approved finding and known remediation context.
Identify missing context	A screenshot is supplied without the affected hostname; prompt for clarification.	Prompt only; do not reject the request or make assumptions automatically.
Summarise client-supplied remediation notes	Convert lengthy implementation notes into a concise retest briefing.	Original evidence must remain available and the summary must not replace it.
Map submitted evidence to affected assets	Highlight which supplied items appear to correspond to which hosts or findings.	Must not claim coverage where identifiers are ambiguous.
Suggest likely evidence categories	For an access-control finding, suggest policy scope or role-membership evidence.	Must not prescribe a single mandatory implementation or claim adequacy.

Automation or AI must not:

- Mark a finding as remediated, verified or closed without assessor validation.
- Decide that client-supplied evidence proves the vulnerability is resolved.
- Invent configuration changes, affected systems or test results.
- Change the original severity or technical conclusion.
- Generate fabricated screenshots, logs or supporting evidence.
- Automatically reject a retest request solely because optional evidence is missing.
- Provide guarantees that a control is compliant, secure or effective beyond the evidence available.

12. Implementation Model

A useful first implementation can remain deliberately conservative. The objective is to improve guidance and information capture before introducing more complex automation or wider remediation integration.

Phase	Reference implementation
Phase 1 - Static evidence guidance	Provide short, pre-approved evidence examples for common finding categories. Keep evidence optional unless a defined validation process requires it.
Phase 2 - Structured readiness notes	Capture simple fields for what changed, affected scope, known exceptions and optional supporting evidence.
Phase 3 - Consultant-facing preparation view	Present the original finding, client notes and evidence together to reduce avoidable back-and-forth.
Phase 4 - Contextual assistance	Optionally use approved automation or AI to tailor evidence suggestions, identify missing context and summarise submitted material without changing finding status.
Phase 5 - Wider remediation integration	Feed readiness and validation states into broader remediation dashboards or cross-assessment workflows if the wider framework matures.

12.1 Adaptation points

- Whether supporting evidence remains optional for all findings or is required for selected retest types.

- Which finding categories receive standard evidence guidance first.
- What evidence types and file formats may be accepted in the chosen implementation.
- How long submitted evidence is retained and who may access it.
- Which status values represent partial, failed, unable-to-validate or changed-condition retests.
- Whether assessors can request additional information before commencing validation.
- Whether automation or AI is required in the initial release or introduced only after the workflow is proven.

13. Risks and Controls

Risk	Why it matters	Control
Evidence treated as proof	Clients or internal users may assume that submitted evidence means the issue is resolved.	State clearly that only independent validation determines the retest outcome.
Excessive evidence burden	A heavy process could discourage clients or create unnecessary administration.	Use proportionate guidance and keep evidence optional where it is not essential.
Generic advice becomes misleading	Evidence expectations vary across technologies and findings.	Use category-based guidance and allow assessment-specific refinement.
Sensitive information submitted unnecessarily	Evidence may contain credentials, personal data or excessive configuration detail.	Provide clear submission guidance, apply data minimisation and use secure storage appropriate to the implementation.
Automation overstates certainty	Automation may infer that a control has been implemented or is effective.	Restrict automation to guidance, completeness checks and summarisation; never allow status decisions.
Consultant workload increases	A poorly designed workflow could add another review step rather than save time.	Present evidence together with the original finding and measure preparation effort during validation.
Partial scope overlooked	A single piece of evidence may be mistaken for full remediation of a multi-asset finding.	Require the readiness record to identify affected scope and known exceptions.
Evidence becomes stale	Submitted material may no longer reflect the environment at the time of validation.	Treat evidence as contextual and perform current technical verification.

14. Validation Criteria

Before adopting the framework in a live process, the workflow should be tested using fictional, historical-approved or otherwise suitable sample findings. Validation should focus on whether it improves preparation without weakening independent assurance.

- Clients can understand the distinction between supporting evidence and verified remediation.
- The readiness record makes it clear what changed and what parts of the original scope were addressed.
- Common finding categories receive relevant, proportionate evidence guidance.
- Assessors can identify exceptions or partial remediation before beginning the retest.
- The workflow does not automatically change finding status based on client-supplied material.
- Assessor preparation time and clarification effort are reduced or remain proportionate.
- Sensitive information is not requested unless it is genuinely useful for validation.
- Any automation remains within the defined assistance boundary.

Success condition

The framework succeeds if it helps the client arrive at a retest better prepared while preserving independent technical validation as the only basis for determining the remediation outcome.

15. Conclusion

Retest preparation is most effective when the client can clearly explain what changed, which parts of the original scope were addressed and whether any exceptions remain. Supporting evidence can make that process more efficient, but it must remain contextual rather than determinative.

This reference framework provides a platform-neutral process for capturing that context, offering relevant evidence guidance and presenting the information to the assessor before validation. It can be adopted manually or implemented within existing security tooling, with optional automation introduced later if it produces measurable value without weakening accountability.

Together with the companion Risk Acceptance for Security Findings framework, this module forms the near-term Remediation Enablement layer of the wider project.

Design position

Help the client arrive at validation better prepared, while ensuring that evidence, workflow automation and AI assistance never replace independent technical verification.

Appendix A - Example Retest Readiness Record

The following example is fictional and illustrates a readiness record only. The supporting information does not prove that remediation has succeeded.

Field	Example record
Finding ID / title	EXT-05 - Deprecated TLS Protocols Supported
Original severity	Medium
Current finding state	Open - Retest Requested
What changed	TLS 1.0 and TLS 1.1 were disabled on the affected external service.
Affected scope addressed	api.example.test:443 and portal.example.test:443
Known exceptions	None reported by the remediation owner.
Supporting evidence	Updated TLS configuration excerpt and current protocol scan output supplied by the client.
Change reference	CHG-2026-0819-04
Readiness statement	Client believes remediation is complete across the affected scope and requests independent validation.
Required consultant action	Retest both affected endpoints from the relevant external test position and confirm the deprecated protocols are no longer offered.
Possible outcomes	Verified/remediated; partially remediated; unresolved; unable to validate; changed condition.

Reminder

The readiness record helps the assessor prepare. The finding must not be marked remediated until the agreed validation activity has been completed.